Explanation script

For the presenter only — this is not part of the report given to the guide.
Blue = roughly what to say. Amber = what to do or show. Green = likely questions and how to answer them.
Target length about 12 minutes, plus questions. Numbers below match the report built on 21 October 2026, commit 371ce53.

Before you start

2 min setup

Have ready, in this order:

- The report PDF open at the architecture diagram (Section 1).
- Four terminals: `python -m plc.plc`, `python dashboard/app.py`, `python -m middleware.middleware_server`, and one free for the attacker.
- The dashboard at `http://127.0.0.1:5050` in a browser, already loaded.
- Optional: the `.pcapng` from `tools.sim_four_laptops` open in Wireshark.

Let the middleware run for two minutes before you demo — the model needs a 120-second warm-up, and you do not want to explain a WARMING_UP badge while someone is watching.

1. Open with the problem, not the solution

1.5 min

"The protocol that industrial plants use to control pumps and valves is called Modbus. It was designed in 1979 for a trusted serial cable, and it has no passwords, no signatures and no encryption. Any device that can reach the PLC can tell it to do anything, and it will obey."

"That is not theoretical. Stuxnet, the Ukrainian grid attacks and the Oldsmar water incident all worked that way — the attacker did not break the protocol, because there was nothing to break."

"You cannot realistically replace the protocol in a working plant. So we put a security layer inside the wire instead. Every command now reaches our middleware first, it decides in under a millisecond, and only then does the command reach the plant. The SCADA software and the PLC are completely unchanged — they do not know we are there."

Point at the architecture diagram while you say the last sentence. Do not list the eight checks yet.

2. The one design decision worth defending

1.5 min

"The thing I would most like to explain is a decision we made about where machine learning belongs."

"The cyber half — is this message genuine, who sent it, have I seen it before — is all deterministic rules. A signature is either valid or it is not. We never want a model guessing about authentication."

"The physical half — would this command actually hurt the plant — has rules too, but it also has a trained model, because 'the plant is behaving oddly' is a judgement no fixed rule captures well."

"And the model is advisory only. It can raise an alert and colour the screen. It can never block a command. Blocking is done entirely by rules a human can read."

> "The reason is in our own measurements: the model misses about half of attack windows and about half of its alarms are false. A component with those numbers must not be allowed to shut down a water plant."

If you only get to make one point in the whole session, make this one. It shows the measurement drove the architecture, not the other way round.

3. Show it working

3 min

Run a legitimate command first, then an attack. Always in that order — the contrast is the point.

> "This is a normal operator command. Green, passed, forwarded to the plant, and the plant responds — you can see the tank level start to move."
>
> "Now the same command, but I have tampered with the value in transit."
>
> "Red, dropped, and it never reached the plant. And this panel is the part I would point out: it is a per-hop trace. It shows every check in order, which one failed — here, the signature — and that the checks after it never ran, because once the signature is wrong there is nothing left worth checking."

Open the packet tracer panel at the bottom of the dashboard. Scroll to the failed check. Pause there for a few seconds; people read it.

> "We built this because a security tool that just says 'blocked' is useless to an operator at three in the morning. The operator has to be able to see why."

4. The results — lead with the honest number

3 min

> Report Sections 4, 5 and 6. Do NOT start with the 100% — start with the model, so you are seen to raise the weakness yourself rather than being asked about it.

"On real SWaT data — a physical water-treatment testbed in Singapore that researchers attacked under controlled conditions — our model gets an ROC-AUC of 0.836 and an F1 of 0.485."

"I want to be direct about what that means. It misses roughly 49% of attack windows, and roughly 54% of its alarms are false."

"Its raw accuracy is 95.9%, and we deliberately do not quote that number, because a model that simply always said 'no attack' would score 96.2% on this data. Attacks are rare, so accuracy flatters you. That is exactly the kind of number that makes a project look good and mean nothing."

"The number that does mean something is per attack event: 8 of 10 attacks detected, median 58 seconds to detect, at about 1.2 false alarms an hour. An operator cares whether the attack was caught, not how many individual seconds were flagged."

"The rules, which are the part that is actually allowed to block, are 4600 out of 4600 correct with zero legitimate commands blocked. But I would not want that read as 'we detect 100% of attacks' — it means these rules do exactly what they are specified to do. A rule only catches the attack it was written for. That is why the model is there at all."

"And end to end, with the real programs running over real sockets: every attack campaign that goes through the middleware is detected, and none of the 40 legitimate commands was blocked."

5. The proof you should be proudest of

1.5 min

"It is easy to write software that reports its own success. So we checked our claims against the network itself."

"We run the whole four-machine lab on one computer and capture the actual packets with tshark — command-line Wireshark. Then we cross-check four separate records of the same events: the captured packets, the middleware's own trace, the blocked-attack log on disk, and the dashboard feed. Four different parts of the system, no reason to agree unless it is all behaving as we say."

"Twenty-four signed frames captured, twenty-four consistent, zero mismatches."

"And the one attack that bypasses us entirely shows up on the PLC's network leg and not on ours — which is exactly what our claim predicts, because an inline device cannot block traffic that never reaches it."

> If Wireshark is open, show the capture here. It lands much harder than a table.

6. What we rejected

1.5 min

> "We trained three machine-learning models and shipped none of them."
>
> "A model for the cyber side got ROC-AUC 0.63 — barely better than guessing. A learned model to fuse the two verdicts looked excellent on validation at 0.93, then scored 0.68 on the test set against 0.83 for the physical model alone — textbook overfitting. And a more sophisticated v3 physical model lost to the simpler v2 on honestly held-out data."
>
> "We kept all three, with their numbers, as documented negative results. In every case the more complex option lost to the simpler one, and the only reason we know that is that we tested on a block we had not tuned on."

7. The audit — volunteer it

1.5 min

> Raise this yourself. If the guide finds it in the report after you have skipped it, it reads very differently.

> "Near the end we ran a deliberately hostile review of our own system — written to find reasons it would fail in a real plant. We froze the state of the system before the review in a folder we never edited, so the before-and-after is checkable rather than remembered."
>
> "It found a critical bug that all of our passing tests had missed: if the PLC was unreachable, the operator was shown a green PASS for a command the plant never received. The screen and the plant disagreed, and the operator would have believed the screen."
>
> "The tests missed it because every one of them checked a component against its own specification, and none of them checked what an operator actually needs. That was the real finding."
>
> "It is fixed, and it is now pinned by tests written from the operator's point of view. The review also found that one unresponsive PLC could stall the entire middleware — that went from two thousand milliseconds a command to under two — and that our own auto-quarantine could be turned against the operator by an attacker forging their address."

8. Close

30 sec

> "So: a working inline security layer for a protocol with no security, fast enough to be invisible at under a millisecond against a one-second control loop, that explains every decision it makes, that has been checked against the network itself, and that is honest about the one component that is not good enough to be trusted with blocking."
>
> "Every number in the report is read automatically from the project's own result files when the PDF is built. Nothing is typed in by hand, so any of it can be regenerated with a single command."

Likely questions

"Why is your model's accuracy so low?"
Do not get defensive. "It is a hard problem on this data, and we chose to report it honestly rather than tune the number. The more important thing is what we did about it: because the model is this weak, we made it advisory, so it cannot block. The blocking is done by deterministic rules. The architecture reflects the measurement."

"Could you not have improved it?"
"We tried three times and measured each one. The more complex models did worse on data they had not been tuned on. The honest limit is the data: SWaT has 35 attack events, and that is not many examples to learn from."

"Is 100% on the rules realistic?"
Agree with the scepticism — it is the right instinct. "It would not be realistic as a detection rate, and we do not claim it as one. Those are specifications, not predictions: an unsigned command must be rejected every time. They only catch the attacks they were written for, which is exactly why there is a model as well."

"What happens if your middleware crashes or is bypassed?"
"Two different answers. If it crashes or errors, it fails closed — the command is dropped, never waved through. If it is bypassed, with the attacker going straight to the PLC, no inline device can stop that, so we do two other things: the PLC now refuses writes from anything that is not the middleware, and the physical model still sees the plant misbehaving afterwards. We show that attack in our results rather than leaving it out."

"Why only one dataset?"
"SWaT is the only public dataset with real physical process data from a real plant under real attacks. We set a rule that it would be our only external source, and that anything else would be clearly labelled synthetic. It costs us some breadth and it keeps us from accidentally reporting simulated results as real ones."

"Have you run it on four actual laptops?"
Answer straight: "Not yet — that is our main outstanding item. Everything is verified on loopback with four separate addresses and a real packet capture, and the tooling and the per-machine checks are written. What is missing is the hardware run." Do not overclaim this one; it is in the limitations section of the report anyway.

> **"What would you do with more time?"**
> "Three things, in order: run it on the four physical laptops; get more attack data than SWaT's 35 events, since that is the real ceiling on the model; and move the dashboard off a development web server if it were ever to be deployed."

Things not to do

- **Do not lead with the 100%.** It invites the one question you least want to answer first.
- **Do not hide the weak model.** Raising it yourself is the strongest move available; being caught on it is the weakest.
- **Do not call the twin results "our accuracy".** They are a simulation measurement and the report labels them that way. Being caught blurring that line would undermine every other number.
- **Do not demo before the model has warmed up** (120 seconds), or you will be explaining a WARMING_UP badge.
- **Do not read the tables aloud.** They are in the report. Say what they mean.

One-line fallback if time is cut short

> "We built a security layer that sits in the wire between a control station and an industrial plant, blocks dangerous commands in under a millisecond using rules a human can audit, uses machine learning only as an advisory signal because we measured it and it is not reliable enough to block, and we verified the whole thing against real captured network traffic."